

Mapeo detallado de preguntas a requisitos OWASP / NIS2 / ENS

Nota: este mapeo es orientativo y debe revisarse jurídicamente antes de usarse en contextos regulatorios formales.

Leyenda

- ID Pregunta: código de la pregunta en el Modelo de Encuesta.
- Tema principal: resumen del foco de la pregunta.
- Referencia OWASP: marco(s) OWASP principal(es) relacionado(s).
- Ámbito NIS2: dominio de obligación de NIS2 con el que se alinea.
- Ámbito ENS: dominio o principio relevante del Esquema Nacional de Seguridad.
- Tipo de indicador: Exposición, Madurez, Resultado, Esfuerzo, Cultura.

Tabla de mapeo (extracto ampliable)

ID Pregunta	Tema principal	Referencia OWASP	Ámbito NIS2 (alto nivel)	Ámbito ENS (alto nivel)	Tipo de indicador
P1.1	Tipo de organización	N/A	Ámbito de aplicación, clasificación de entidades	Ámbito de aplicación ENS	Contexto
P1.2	Tamaño de la organización	N/A	Proporcionalidad de medidas	Proporcionalidad de medidas	Contexto
P1.4	Situación respecto al ENS	N/A	Sinergias ENS-NIS2	Certificación / adecuación ENS	Contexto
P1.5	Situación respecto a NIS2	N/A	Determinación de entidad esencial/importante	Relación ENS-NIS2	Contexto
P2.1	Marco de gestión de riesgos	OWASP Risk Rating Methodology	Gestión de riesgos	Análisis y gestión de riesgos	Madurez
P2.2	Frecuencia de revisión de riesgos	OWASP Risk Rating Methodology	Gestión de riesgos continua	Mejora continua	Madurez
P2.3	Implicación de alta dirección	OWASP SAMM – Governance	Gobernanza, responsabilidad de dirección	Principio de organización y marco organizativo	Cultura / Madurez
P2.4	Uso de indicadores cuantitativos	OWASP SAMM – Strategy and Metrics	Medidas técnicas y organizativas basadas en riesgo	Métricas y seguimiento	Madurez
P2.5	Índice Global de Madurez (IGM)	OWASP SAMM – Strategy and Metrics	Gestión de riesgos, gobernanza	Mejora continua	Resultado
P3.1	Conocimiento del Top 10:2025	OWASP Top 10:2025	Medidas técnicas de protección	Medidas de protección (integridad, confidencialidad)	Cultura
P3.2	Mapeo de vulnerabilidades a Top 10	OWASP Top 10:2025	Gestión de vulnerabilidades	Gestión de vulnerabilidades	Esfuerzo / Exposición

P3.3	Categoría OWASP más frecuente	OWASP Top 10:2025	Identificación de riesgos predominantes	Análisis de riesgos	Exposición
P3.4	Cobertura de análisis frente a Top 10	OWASP Top 10:2025	Medidas técnicas de detección	Monitorización y detección	Esfuerzo
P3.5	MTTR de vulnerabilidades Top 10	OWASP Top 10:2025 / Risk Rating	Respuesta a incidentes y remediación	Tiempo de respuesta y remediación	Resultado
P3.6	Priorización de A01-A03	OWASP Top 10:2025	Gestión de riesgos, cadena de suministro	Medidas reforzadas para sistemas críticos	Madurez
P4.1	Uso de SAMM	OWASP SAMM	Gestión de riesgos de aplicaciones	Gestión de la seguridad de sistemas de información	Madurez
P4.2	Cobertura de autoevaluaciones SAMM	OWASP SAMM	Medidas organizativas	Auditoría y revisión	Esfuerzo
P4.3	Nivel medio de madurez SAMM	OWASP SAMM	Gestión de riesgos estructural	Mejora continua	Resultado
P4.4	Estado de "Strategy and Metrics"	OWASP SAMM – Strategy and Metrics	Gobernanza basada en métricas	Política de seguridad y supervisión	Madurez
P4.5	Uso de SAMM para inversiones	OWASP SAMM	Gobernanza, priorización de recursos	Planificación de la seguridad	Madurez
P4.6	Frecuencia de revisión SAMM	OWASP SAMM	Mejora continua	Revisiones y auditorías periódicas	Esfuerzo
P5.1	Conocimiento y uso de ASVS	OWASP ASVS 5.0	Medidas técnicas sobre aplicaciones	Medidas de protección específicas	Madurez
P5.2	Clasificación ASVS de aplicaciones	OWASP ASVS 5.0	Gestión de activos críticos	Inventario y clasificación de sistemas	Esfuerzo
P5.3	% apps críticas en ASVS Nivel 2	OWASP ASVS 5.0	Medidas técnicas proporcionales a riesgo	Medidas reforzadas para sistemas de categoría media/alta	Resultado

P5.4	Uso de ASVS en el SDLC	OWASP ASVS 5.0	Medidas organizativas y técnicas en desarrollo	Ciclo de vida de la seguridad	Madurez
P5.5	Cobertura de pruebas vs ASVS	OWASP ASVS 5.0	Medidas técnicas de verificación	Verificación y pruebas	Esfuerzo
P5.6	Defectos ASVS en producción	OWASP ASVS 5.0	Incidentes y fallos de seguridad	Registro de incidentes y lecciones aprendidas	Resultado
P6.1	Uso de Risk Rating OWASP	OWASP Risk Rating Methodology	Gestión de riesgos de ciberseguridad	Análisis de riesgos	Madurez
P6.2	Factores usados en evaluación	OWASP Risk Rating Methodology	Enfoque basado en riesgo	Enfoque basado en riesgo	Esfuerzo
P6.3	Clasificación del riesgo resultante	OWASP Risk Rating Methodology	Gestión integral de riesgos	Criterios de aceptación de riesgos	Madurez
P6.4	Uso del riesgo para priorizar	OWASP Risk Rating Methodology	Medidas proporcionales a riesgo	Priorización de medidas	Resultado
P6.5	Aceptación de riesgos altos	OWASP Risk Rating Methodology / SAMM Governance	Gobernanza, responsabilidad de alta dirección	Decisión de aceptación de riesgos	Cultura / Madurez
P7.1	Formación OWASP para personal técnico	OWASP Top 10, SAMM, ASVS	Medidas organizativas (formación)	Formación y concienciación	Esfuerzo
P7.2	Concienciación para personal no técnico	OWASP Top 10 (adaptado)	Concienciación de usuarios	Formación y concienciación	Esfuerzo
P7.3	Security champions	OWASP SAMM – Governance & Implementation	Organización y roles de seguridad	Organización de la seguridad	Cultura
P7.4	Cultura de reporte interno	OWASP SAMM – Governance / Operations	Gestión de incidentes y near misses	Registro y canal de incidentes	Cultura

P7.5	Tiempo hasta agenda de dirección	OWASP Risk Rating Methodology	Gobernanza, reporting a la alta dirección	Gestión de incidentes y comunicación	Resultado
P8.1	Inventario de proveedores TIC	OWASP Top 10 A03 (Supply Chain)	Seguridad de la cadena de suministro	Gestión de proveedores y servicios externos	Esfuerzo
P8.2	Evaluación de seguridad de proveedores	OWASP Top 10 A03 / SAMM	Cadena de suministro, gestión de terceros	Evaluación de terceros	Madurez
P8.3	Requisitos OWASP/ASVS en contratos	OWASP ASVS / Top 10	Medidas contractuales, cadena de suministro	Exigencias a terceros	Esfuerzo
P8.4	Gestión de vulnerabilidades de componentes	OWASP Top 10 A03 / ASVS	Cadena de suministro, gestión de parches	Gestión de cambios y parches	Resultado
P9.1	Registro y gestión de incidentes	OWASP SAMM – Operations	Gestión de incidentes y notificación	Gestión de incidentes ENS	Madurez
P9.2	Coordinación con CSIRTs nacionales	N/A (pero coherente con prácticas OWASP)	Cooperación y notificación a autoridades	Coordinación con CCN-CERT / INCIBE-CERT	Esfuerzo
P9.3	Planes de continuidad y pruebas	OWASP SAMM – Operations	Continuidad y resiliencia	Continuidad del servicio	Madurez

Este extracto cubre las preguntas más representativas. El mapeo completo puede extenderse a cualquier pregunta adicional o versión sectorial de la encuesta, siguiendo la misma estructura.